OWASP TOP 10:2025 — REMEDIATION PLAN

Epotech Cybersecurity Platform **Date: 2026-10-29 | Version 1.0**

> **CAUTION: APPROVAL REQUIRED**
> No code changes have been made. This document lists the specific technical changes to be implemented. Reply "Proceed" or approve individual items to authorize implementation.

REMEDIATION 1 — EPOTK-001

CRITICAL

Title: Remove Email-Based Admin Role Inference | **Priority:** P1 — Implement before any other change
Files to modify: `src/lib/auth.js`, `src/pages/AuthPage.jsx`

Change 1 of 3 — `src/lib/auth.js` (Complete Replacement)

```
// BEFORE (Vulnerable):
export function getUserRole(user) {
  if (!user) return null;
  if (user.role) return user.role;
  const email = (user.email || '').toLowerCase();
  if (email.includes('admin')) return 'admin';   // ← REMOVE THIS
  return 'client';
}
```

Change 2 of 3 — `src/pages/AuthPage.jsx` (Post-Login Navigation)

```
// BEFORE (Vulnerable):
const userEmail = data.user.email?.toLowerCase() || '';
navigate(userEmail.includes('admin') ? '/admin' : '/dashboard');

// AFTER (Role-based from app_metadata):
```

Change 3 of 3 — Server-Side Admin Assignment (FastAPI Backend)

```
# In FastAPI backend using service_role key (NEVER anon key):
supabase_admin.auth.admin.update_user_by_id(
    user_id,
    {"app_metadata": {"role": "admin"}}
)
```

Side Effects: Any existing user who was accessing admin via email-based role will lose access. Admin role must be explicitly granted via the backend.

Regression Test

```
// Test 1: User with 'admin' in email without server role should return 'client'
const maliciousUser = { email: 'hacker.admin@evil.com', app_metadata: {} };
assert(getUserRole(maliciousUser) === 'client');

// Test 2: Should return 'admin' ONLY when server-set app_metadata.role exists
```

REMEDIATION 2 — EPOTK-002

CRITICAL

Title: Rotate Exposed Credentials | **Priority:** P1 — Immediate | **Scope:** Operational / Infrastructure (No application code changes required)

1. **Rotate Supabase Anon Key:**
   - Navigate to: Supabase Dashboard → Project `rwfbcsedjgpesnbfeprd` → Settings → API.
   - Click **"Regenerate"** on the anon/public key.
   - Update the new key in Vercel Dashboard → Environment Variables ONLY (do NOT place in `.env` files).
2. **Revoke Vercel OIDC Token:**
   - Navigate to: Vercel Dashboard → Settings → Tokens.
   - Revoke all tokens associated with project reference `ragavs-projects-5cf0fb76`.
   - Re-authenticate local Vercel CLI environments.
3. **Clean Git Repository History:**

```
git log --all --full-history -- .env .env.local
# If history commits exist, purge completely:
git filter-repo --path .env --invert-paths
git filter-repo --path .env.local --invert-paths
git push --force-with-lease
```

4. **Enforce Git Untracking:**

```
git rm --cached .env .env.local 2>/dev/null || true
echo ".env*" >> .gitignore
git commit -m "security: remove env files from tracking"
```

5. **Update `.env.example`:** Ensure only non-sensitive dummy placeholders exist.

REMEDIATION 3 — EPOTK-003

HIGH

Title: Replace Permissive Row Level Security (RLS) Policies | **File:** `supabase_schema.sql`

> **WARNING: SEQUENCE DEPENDENCY**
> Execute these SQL statements in the Supabase SQL Editor AFTER rotating credentials (Remediation 2). Applying these policies will immediately enforce authentication for all database operations.

```
-- STEP 1: Remove all overly permissive policies
DROP POLICY IF EXISTS "Allow select service_requests" ON public.service_requests;
DROP POLICY IF EXISTS "Allow insert service_requests" ON public.service_requests;
DROP POLICY IF EXISTS "Allow update service_requests" ON public.service_requests;
DROP POLICY IF EXISTS "Allow select security_audits" ON public.security_audits;
DROP POLICY IF EXISTS "Allow insert security_audits" ON public.security_audits;

-- STEP 2: Create user-scoped policies for service_requests
CREATE POLICY "Users read own requests" ON public.service_requests
    FOR SELECT TO authenticated USING (auth.uid() = user_id);

CREATE POLICY "Users insert own requests" ON public.service_requests
    FOR INSERT TO authenticated WITH CHECK (auth.uid() = user_id);

CREATE POLICY "Admins manage all requests" ON public.service_requests
```

Side Effects: The `apiClient.js` fallback fetching requests anonymously will fail. Application must use authenticated sessions.

REMEDIATION 4 — EPOTK-004

MEDIUM

Title: Remove Authentication Bypass Paths | **File:** `src/pages/AuthPage.jsx`

Change 1 — Gate Demo Persona Buttons to DEV Mode Only

```
{/* AFTER — Only rendered in development builds: */}
{import.meta.env.DEV && (
  <div className="grid grid-cols-2 gap-2.5">
    <button onClick={() => handleQuickLogin('admin@epotech.com')}>Admin Persona [DEV]</button>
    <button onClick={() => handleQuickLogin('client@epotech.io')}>Client Persona [DEV]</button>
```

Change 2 — Remove Network-Error Fallback Session Grant

```
// AFTER — Show explicit network error, never grant session:
if (errMsg.includes('Failed to fetch') || errMsg.includes('NetworkError')) {
  setError('Unable to reach authentication server. Please check your connection and try again.');
  setLoading(false);
```

Change 3 — Hard Fail Unconfigured Supabase in Production

```
// AFTER — Fail hard in production builds if Supabase client missing:
if (import.meta.env.PROD) {
  setError('Authentication service not configured. Contact system administrator.');
  setLoading(false);
```

REMEDIATION 5 — EPOTK-005

MEDIUM

Title: Add Missing Security Headers | **File:** `vercel.json`

```
{
  "headers": [
    {
      "source": "/(.*)",
      "headers": [
        { "key": "Strict-Transport-Security", "value": "max-age=31536000; includeSubDomains; preload" },
        { "key": "X-Frame-Options", "value": "DENY" },
```

REMEDIATION 6 & MINOR — EPOTK-006 & EPOTK-I01

LOW / INFO

Sentry Security Logging Integration (`src/pages/AuthPage.jsx` & `src/App.jsx`)

```
import * as Sentry from '@sentry/react';

// In AuthPage.jsx catch block:
Sentry.captureEvent({ message: 'Authentication failure', level: 'warning', tags: { component: 'AuthPage' }
```

Remove Hardcoded Personal PII (`src/components/Navbar.jsx`)

```
const ADMIN_EMAIL = 'sriragavsurya@gmail.com';  // ← DELETE THIS LINE
```

Plan Version: 1.0 (2026-10-29) **Status:** AWAITING FORMAL APPROVAL **Assessor:** Antigravity AI Security Engine